GOUTHAMAN G

Tiruchirappalli | +91 8675115970 | goutham240605@gmail.com
LinkedIn | GitHub | Portfolio

Summary

Final-year B.Tech Cyber Security student focused on application and API security. Builds security tooling that finds and prevents access control flaws (BOLA/IDOR, privilege escalation, mass assignment) across REST, SOAP, and GraphQL, validated against intentionally vulnerable targets. Completed 55+ PortSwigger Web Security Academy labs; holds CASA; pursuing PJPT.

Education

Amrita Vishwa Vidyapeetham, Coimbatore 2027
B.Tech, Computer Science and Engineering – Cyber Security CGPA: 7.5/10

Skills

Offensive Security: Burp Suite, Nmap, Wireshark, Kali Linux

Application Security: OWASP Top 10, OWASP API Security Top 10, Broken Access Control, IDOR/BOLA, Mass Assignment, Privilege Escalation, SQLi, XSS, SSRF, JWT Security, GraphQL Security, Authentication and Session Management, CVSS v3.1

Languages: Python, TypeScript, Bash

Engineering and DevOps: FastAPI, React, SQLAlchemy, PostgreSQL, Git, GitHub Actions, pytest

Projects

Multi-Protocol API Security Testing Framework Link

- Engineered Aegis-API, a unified REST, GraphQL, and SOAP security scanner covering the OWASP API Top 10, with automated protocol routing, Swagger/OpenAPI contract enumeration, parameter discovery, and wordlist synthesis.
- Developed an Action-Level BOLA & IDOR engine using a Two-User Tri-Request protocol and state-differential analysis across CRUD operations, sub-resources, and parameter manipulation, validated against crAPI.
- Built mass assignment detection using GET-PUT-GET state verification, JWT analysis (alg:none, algorithm confusion, weak secrets, kid injection), and rate-limit testing (burst, throttle, and header checks); confirmed a real mass assignment flaw on a crAPI order endpoint.
- Built GraphQL and SOAP scanners for AST query-depth exhaustion, field-level authorization bypass, batching credential stuffing, in-band XXE file disclosure, XML injection, and WS-Security analysis.
- Integrated CVSS v3.1 scoring using the FIRST formula, automated PDF/CSV reporting, and configurable CI/CD severity gates (GitHub Actions) for DevSecOps pipelines.

Schema-Aware Zero-Trust Gateway for Preventing GraphQL BOLA *In Progress*

- Developing a zero-trust gateway that sits in front of GraphQL APIs and detects and blocks Broken Object Level Authorization (BOLA) before requests reach the backend.
- Enforcing ownership-based authorization checks that use the GraphQL schema to find object ID arguments and confirm the authenticated user owns each requested object.
- Implementing AST-based query canonicalization to resolve aliases and fragments, so disguised queries are normalized before any authorization decision.
- Adding rate limiting to stop batched and alias-based BOLA enumeration, where one request tries many object IDs.

Security Research and Bug Bounty

Bug Bounty — Intigriti

- Hunting public programs for IDOR/BOLA, authentication, session, and API flaws using recon, JavaScript analysis, and Burp Suite.

PortSwigger Web Security Academy Write-ups

- Completed 55+ Apprentice and Practitioner labs: XSS, SQLi, CSRF, access control, authentication, path traversal, JWT, GraphQL, and API testing.
- Documented each topic with concept notes and step-by-step lab write-ups and published on GitHub.

Certifications

Certified API Security Analyst (CASA) — APIsec University

Practical Junior Penetration Tester (PJPT) — TCM Security In Progress